

# Лекция 8

Построение системы защиты от угрозы  
нарушения целостности и доступности  
информации

# Учебные вопросы:

1. Методы и технологии обеспечения целостности информации
2. Методы и технологии обеспечения доступности (сохранности) данных

## Дополнительный материал:



# 1 Методы и технологии обеспечения целостности информации



Понятие целостности данных в научной литературе имеет несколько определений. В одной из наиболее распространенных трактовок под целостностью данных подразумевается отсутствие ненадлежащих изменений. Смысл понятия «ненадлежащее изменение» раскрывается Д. Кларком и Д. Вилсоном:

- ни одному пользователю автоматизированной системы, в том числе и авторизованному, не должны быть разрешены такие изменения данных, которые повлекут за собой их разрушение или потерю.

Организационно-технологические меры защиты целостности информации на электронных носителях можно разделить на две основные группы:

- организационные меры по поддержке целостности информации;
- технологические меры контроля целостности битовых последовательностей.



## Создание резервных копий

Создание резервных копий информации, хранимой в информационной системе, должно быть обязательной регулярной процедурой, периодичность которой зависит от важности информации и технологии ее обработки, в частности от объема вводимых данных, возможности повторного ввода и т. д. Для создания резервных копий могут использоваться как стандартные утилиты, так и специализированные системы резервного копирования, адаптированные к конкретной системе.

При ведении резервных копий необходимо регулярно проверять сохранность и целостность находящейся в них информации.

## Обеспечение правильных условий хранения и эксплуатации

- Регистрация и учет носителей ведутся независимо от наличия конфиденциальной информации. Служебные носители должны иметь этикетку с грифом, номером и датой регистрации. Учет ведется в журнале на протяжении всего срока использования. В помещении не должно быть личных носителей, а работа с непроверенными носителями запрещена. Проводятся систематические проверки наличия носителей и информации.
- Электронные носители хранятся как обычные документы с исключением НСД. Передача между подразделениями осуществляется под расписку и учитывается в журнале. Вынос за пределы помещения возможен только с разрешения.



- Жесткий диск регистрируется по категории компьютера, независимо от его использования. На корпусе должна быть соответствующая этикетка. При ремонте компьютера необходимо изъять диск, удалить информацию или присутствовать при ремонте.
- Копирование файлов с зарегистрированных носителей допускается только на компьютерах с категорией не ниже грифа носителя. Каждое копирование учитывается в журнале.
- Особое внимание нужно уделять физическому удалению данных с носителей. Обычное удаление файлов стирает их только на логическом уровне, оставляя данные доступными. В современных системах информация сохраняется в нескольких экземплярах под разными именами.



- Рассмотрим технологические меры контроля целостности данных на электронных носителях. Целостность проверяется с помощью контрольного кода, который записывается после областей данных с маркерами.
- Циклический контрольный код эффективен против случайных ошибок, но не защищает от целенаправленных атак. Для этого используют криптографические методы имитозащиты, обеспечивающие надежную защиту данных, но требующие значительных вычислительных ресурсов.



- При рассмотрении вопроса целостности данных при обработке используется интегрированный подход, основанный на ряде работ Д. Кларка и Д. Вилсона, а также их последователей и оппонентов и включающий в себя девять теоретических принципов:
  - корректность транзакций;
  - аутентификация пользователей;
  - минимизация привилегий;
  - разграничение функциональных обязанностей;
  - аудит произошедших событий;
  - объективный контроль;
  - управление передачей привилегий;
  - обеспечение непрерывной работоспособности;
  - простота использования защитных механизмов.

# Корректность транзакций

- Корректность транзакций означает, что данные можно изменять только определенными способами, чтобы сохранить их целостность. Это исключает произвольные модификации. Каждая транзакция должна быть доказуемо корректной.
- Второй принцип гласит, что изменение данных может осуществляться только специально аутентифицированными для этой цели пользователями. Данный принцип работает совместно с последующими четырьмя, с которыми тесно связана его роль в общей схеме обеспечения целостности.

# Минимизация привилегий

- Идея минимизации привилегий появилась еще на ранних этапах развития информационной безопасности в форме ограничения, накладываемого на возможности выполняющихся в системе процессов и подразумевающего то, что процессы должны быть наделены теми и только теми привилегиями, которые естественно и минимально необходимы для выполнения процессов. Принцип минимизации привилегий распространяется и на программы, и на пользователей. Пользователи имеют, как правило, несколько больше привилегий, чем им необходимо для выполнения конкретного действия в данный момент времени. А это открывает возможности для злоупотреблений. Разграничение функциональных обязанностей подразумевает организацию работы с данными таким образом, что в каждой из ключевых стадий, составляющих единый критически важный, с точки зрения целостности, процесс, необходимо участие различных пользователей. Это гарантирует невозможность выполнения одним пользователем всего процесса целиком (или даже двух его стадий) с тем, чтобы нарушить целостность данных.

# Аудит произошедших событий

- Аудит произошедших событий, включая возможность восстановления полной картины происшедшего, является превентивной мерой в отношении потенциальных нарушителей.
- Принцип объективного контроля также является одним из краеугольных камней политики контроля целостности. Суть данного принципа заключается в том, что контроль целостности данных имеет смысл лишь тогда, когда эти данные отражают реальное положение вещей. В связи с этим Кларк и Вилсон указывают на необходимость регулярных проверок, имеющих целью выявление возможных несоответствий между защищаемыми данными и объективной реальностью, которую они отражают.

# Управление передачей привилегий

- Управление передачей привилегий необходимо для эффективной работы всей политики безопасности. Если схема назначения привилегий неадекватно отражает организационную структуру предприятия или не позволяет администраторам безопасности гибко манипулировать ею для обеспечения эффективности производственной деятельности, защита становится обременительной и провоцирует попытки обойти ее.
- Принцип обеспечения непрерывной работы включает защиту от сбоев, стихийных бедствий и других форс-мажорных обстоятельств.

# Имитовставка

- Для обеспечения целостности в текст сообщения часто вводится некоторая дополнительная информация, которая легко вычисляется, если секретный ключ известен, и является трудно вычислимой в противном случае. Если такая информация вырабатывается и проверяется с помощью одного и того же секретного ключа, то ее называют имитовставкой (в зарубежных источниках используется термин код аутентификации сообщений — Message Authentication Code (MAC) — поскольку помимо целостности может обеспечиваться еще и аутентификация объекта). Имитовставкой может служить значение хэш-функции, зависящей от секретного ключа, или выходные данные алгоритма шифрования в режиме сцепления блоков шифра.

# Шифрование

- Целостность данных можно обеспечить и с помощью их шифрования симметричным криптографическим алгоритмом при условии, что подлежащий защите текст обладает некоторой избыточностью. Последняя необходима для того, чтобы нарушитель, не зная ключа шифрования, не смог бы создать шифрограмму.
- Избыточности можно достигнуть многими способами. В одних случаях текст может обладать достаточной естественной избыточностью (например, в тексте, написанном на любом языке, разные буквы и буквосочетания встречаются с разной частотой). В других можно присоединить к тексту до шифрования некоторое контрольное значение, которое, в отличие от имитовставки и цифровой подписи, не обязательно должно вырабатываться криптографическими алгоритмами, а может представлять собой просто последовательность заранее определенных символов.

# Контроль целостности потока сообщений

- Контроль целостности потока сообщений обнаруживает их повтор, задержку, переупорядочение или утрату. Каждое сообщение защищается шифрованием, имитовставкой или цифровой подписью. Для контроля целостности используются:
  - \* порядковый номер целостности с именем источника, который приемник сравнивает с предыдущим;
  - \* сцепление с предыдущим сообщением в алгоритмах шифрования.
- При временном номере проверяется близость времени отправки и приема с учетом задержки и разности хода часов.

# Электронная подпись

- Электронная подпись (ЭЦП) — метод подтверждения подлинности автора сообщения при спорах об авторстве. Используется в системах без взаимного доверия (финансовые системы, контроль международных договоров). Предложена Диффи и Хеллманом в 1976 году. Каждый абонент имеет личный секретный ключ для формирования подписи и открытый ключ для её проверки. Цифровая подпись вычисляется на основе сообщения и секретного ключа отправителя, что позволяет получателю с открытым ключом аутентифицировать сообщение.

- ЭЦП в цифровых документах заменяет ручную подпись в бумажных: это данные, подтверждающие автора и целостность сообщения. Получатель или третья сторона может проверить подлинность автора и сохранность данных.
- Если пользователь соблюдает нормы безопасности (хранит ключи, использует чистое ПО), стойкость системы зависит только от криптографических качеств.

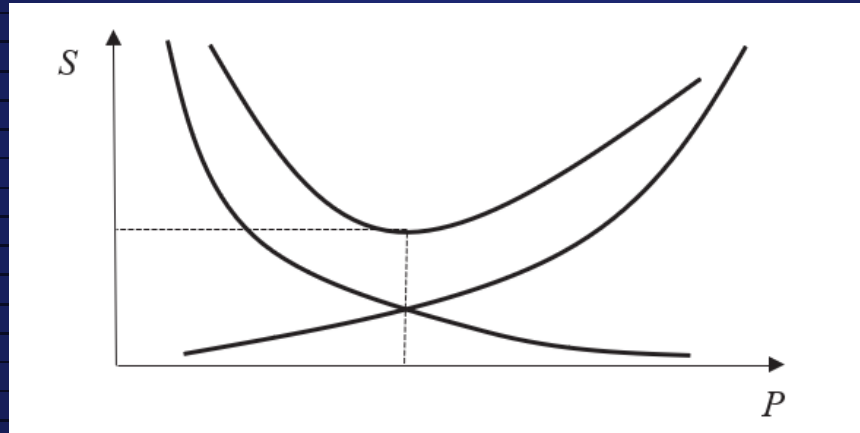
## 2 Методы и технологии обеспечения доступности (сохранности) данных

Поскольку одной из основных задач информационной системы является своевременное обеспечение пользователей системы необходимой информацией (сведениями, данными, управляющими воздействиями и т. п.), то угроза отказа доступа к информации может еще рассматриваться как угроза отказа в обслуживании или угроза отказа функционирования.

Часто невозможно бывает разделить причины отказа. В связи с этим вводят понятие надежности. Надежность — свойство объекта сохранять во времени значения всех параметров, характеризующих способность выполнять требуемые функции в заданных режимах и условиях применения, технического обслуживания, ремонта, хранения и транспортировки. Для оценки надежности функционирования информационной системы не важно, вызваны ли отказы действиями злоумышленника или связаны с ошибками разработки, важно, как и в каком объеме произойдет их парирование.

- Оценка надежности оборудования основана на следующем подходе.
- Элементная надежность любого устройства или системы в целом оценивается как произведение вероятности безотказной работы  $P_{\Sigma}(t)$  на коэффициент готовности  $K_r$  :
- $P_0(t) = P_{\Sigma}(t)K_r$ .

- Если надежность выступает в качестве одной из мер эффективности системы, то оптимальным ее значением является такое, при котором стоимость эксплуатации является минимальной. Оптимальное значение показателя надежности может быть оценено графически



- Зависимость затрат от надежности:
- $S_{\text{э}}$  — эксплуатационные затраты;  $S_{\text{р}}$  — затраты на разработку

- На начальной стадии проектирования используют простые модели или элементарные методики расчета надежности, предполагающие самостоятельность элементов. Наиболее распространены методики расчета по элементам, где надежность описывается формулами:

- \* частота отказов

$$f(t) = dq(t)/dt = - dP(t)/dt;$$

- \* ИНТЕНСИВНОСТЬ ОТКАЗОВ

$$\lambda(t) = \frac{1}{P(t)} \frac{dq(t)}{dt} = - \frac{1}{P(t)} \frac{dP(t)}{dt};$$

- \* среднее время безотказной работы

$$t_{cp} = \int_0^{\infty} t \cdot f(t) dt,$$

- где ( P ) – вероятность безотказной работы, ( q ) – вероятность отказа.
- Эти формулы применимы к системам с любым числом элементов.

- Вероятность безотказной работы системы является функцией вероятностей безотказной работы входящих в систему элементов

$$P_c = f_1 [P_1(t), P_2(t), \dots, P_n(t)].$$

- Взаимосвязь функций для отдельных элементов может быть разной. В частности, вероятность безотказной работы или функция надежности системы, состоящей из  $n$  произвольно соединенных элементов, может быть выражена в виде полинома

$$P_c = \sum_{i=1}^k a_i P_i.$$

- При независимом влиянии элементов на работоспособность установки, где отказ каждого элемента приводит к отказу системы, схема надежности представляется в виде последовательного соединения. Вероятность безотказной работы системы равна произведению вероятностей безотказной работы элементов.

$$P_c(t) = \prod_{i=1}^n P_i(t).$$

- Надежность элементов трудно характеризовать вероятностью безотказной работы для малых периодов времени, так как значения  $P_i(t)$  близки к единице. В таких случаях лучше использовать интенсивность отказов, которая показывает плотность вероятности отказа элемента. Она определяется количеством отказов  $p_i$  в единицу времени  $\Delta t$  относительно количества исправных элементов  $N$ .

$$\lambda = \frac{n_i}{N \Delta t}.$$

- Вероятность безотказной работы связана с интенсивностью отказов следующим соотношением:

$$P(t) = \exp\left(-\int_0^t \lambda(t) dt\right).$$

- Функция  $\lambda(t)$  имеет вид, изображенный на рис. 6.2

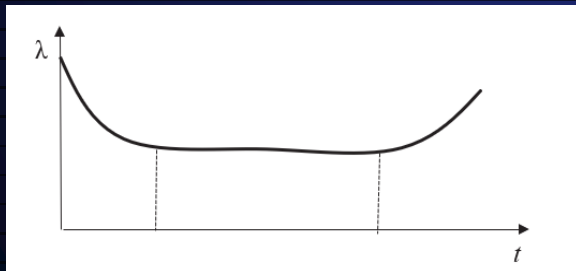


Рис. 6.2. Изменение интенсивности отказов системы в течение срока службы

- Первый участок повышенной интенсивности отказов связан с скрытыми неисправностями, допущенными при проектировании или нарушении технологии изготовления. Второй участок характеризуется нормальной эксплуатацией, учитываемой при расчете надежности. Третий участок связан с износом оборудования.
- Простые устройства надежнее сложных. В информационных системах надежность аппаратных компонентов часто не учитывается из-за быстрого морального старения. Надежность системы зависит от программного обеспечения.



- Отличия программного обеспечения:

- \* ошибки не случайны;
- \* зависят от технологии разработки и квалификации;
- \* не связаны со временем;
- \* вызваны входными данными.

- Подходы к защите программного обеспечения:

- 1. Отказоустойчивость: обнаружение и парирование ошибок с помощью избыточности.
- 2. Предотвращение неисправностей: анализ ошибок и их причин на всех этапах разработки.